

FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO
CAMPUS LIBERDADE
BACHARELADO EM CIÊNCIA DA COMPUTAÇÃO

GABRIEL CARVALHO MOTA
GUILHERME DE LIMA SIQUEIRA
RODRIGO LUIZ MENEZES DOS REIS
VITORIA LETICIA MACIEL DA SILVA

SMART TENNIS ARENA
RELATÓRIO DE VULNERABILIDADES E PLANO DE SEGURANÇA DO
FIRMWARE

São Paulo, 2026

Sumário

RESUMO	3
1. INTRODUÇÃO	3
2. OBJETIVOS	4
2.1 Objetivo Geral	4
2.2 Objetivos Específicos	4
3. FUNDAMENTAÇÃO TEÓRICA.....	4
3.1 Bluetooth Low Energy (BLE) e Segurança GATT.....	4
3.2 Cibersegurança em Dispositivos IoT Desportivos	5
4. METODOLOGIA E ARQUITETURA DE HARDWARE	6
4.1. Gestão de Energia e Disponibilidade Física.....	6
5. FRONTEIRAS DE CONFIANÇA E FLUXO D DADOS	7
6. ANÁLISE DE VULNERABILIDADES	8
6.1. V01 - Ausência de Autenticação e <i>Bonding</i> no Emparelhamento BLE.....	8
6.2. V02 - Risco de Sequestro de Ligação (<i>Connection Hijacking</i>)	8
6.3. V01 - Transmissão de Telemetria de Impacto em Texto Plano	9
6.4. V04 - Inexistência de Mecanismo de Parada Segura (RF22)	9
7. CONSIDERAÇÕES FINAIS.....	10
8. APÊNDICE.....	11
9. REFERÊNCIAS	13

RESUMO

Este documento apresenta a análise de vulnerabilidades e o plano de segurança focado na primeira iteração do *firmware* do dispositivo IoT (baseado no microcontrolador ESP32) desenvolvido para o projeto interdisciplinar "Smart Tennis Arena". A análise incide sobre a arquitetura de comunicação sem fios Bluetooth Low Energy (BLE), a aquisição de dados físicos via acelerómetro MPU6050 e a gestão de energia do sistema. Através de uma revisão estática do código-fonte em C++, foram identificadas vulnerabilidades relacionadas com a ausência de autenticação no emparelhamento, transmissão de dados em texto plano e a inexistência de um mecanismo de parada segura (RF22). O relatório propõe mitigações arquiteturais para garantir a confidencialidade, integridade e disponibilidade do sistema antes da sua integração com a aplicação móvel e a API do projeto.

1. INTRODUÇÃO

O projeto Smart Tennis Arena visa o desenvolvimento de uma solução integrada de IoT e Robótica para a criação e execução de treinos gamificados de ténis. O ecossistema é composto por um aplicativo *mobile*, uma API, um *dashboard web* e um alvo físico (o "João Bobo") equipado com sensores e atuadores.

No contexto da Unidade Curricular de Redes de Computadores e Cibersegurança, a proteção da comunicação entre os componentes físicos e as interfaces de *software* é um requisito fundamental. A comunicação sem fios num ambiente desportivo, especialmente quando lida com dados de desempenho e comandos de atuação mecânica, está sujeita a interceções, injeção de dados e ataques de negação de serviço (DoS).

A iteração atual do *firmware* marca uma evolução significativa na engenharia do projeto. O sistema transitou de um modelo de bloqueio temporal (`delay()`) para uma arquitetura assíncrona baseada em `millis()`, garantindo a leitura contínua do acelerómetro MPU6050 a aproximadamente 100 Hz. Adicionalmente, o cálculo físico evoluiu da simples leitura de força resultante para a medição do impulso (`deltaForca`), permitindo distinguir uma pancada real do balanço natural do boneco. Contudo, a migração recente para a pilha Bluetooth Low Energy (BLE) expôs novas superfícies de ataque que requerem documentação e tratamento adequado.

2. OBJETIVOS

2.1 Objetivo Geral

Identificar, documentar e propor mitigações para as vulnerabilidades de segurança presentes no *firmware* do módulo IoT (ESP32) e na sua comunicação BLE com o ecossistema Smart Tennis Arena, assegurando o cumprimento dos requisitos não funcionais de cibersegurança do edital.

2.2 Objetivos Específicos

- Mapear as fronteiras de confiança do sistema embarcado.
- Analisar a implementação do protocolo BLE quanto a falhas de autenticação e confidencialidade.
- Avaliar a robustez do código contra ataques de exaustão de recursos e negação de serviço.
- Verificar a conformidade do *hardware* e *software* com o requisito funcional de parada segura (RF22).
- Documentar a arquitetura elétrica e a autonomia do sistema, correlacionando-as com a disponibilidade do serviço.

3. FUNDAMENTAÇÃO TEÓRICA

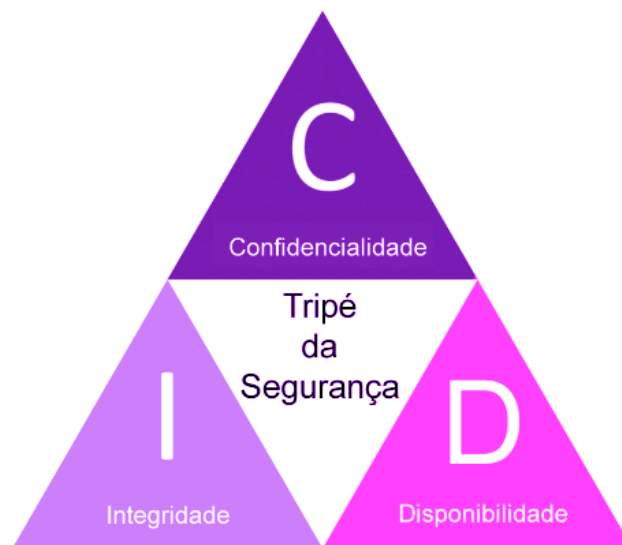
3.1 Bluetooth Low Energy (BLE) e Segurança GATT

O BLE é um protocolo de comunicação sem fios desenhado para baixo consumo energético. Funciona com base no Perfil de Atributos Genéricos (GATT), que organiza os dados em Serviços e Características (*Characteristics*). Por omissão, as características BLE não possuem encriptação. Para garantir a segurança, a especificação do Bluetooth exige a implementação do *Security Manager Protocol* (SMP), que gere o processo de *Pairing* e *Bonding*. Sem este processo, os dados transmitidos (como as notificações de impacto) trafegam em texto plano, suscetíveis a ataques de *sniffing* por qualquer dispositivo com uma antena de 2.4 GHz na proximidade.

3.2 Cibersegurança em Dispositivos IoT Desportivos

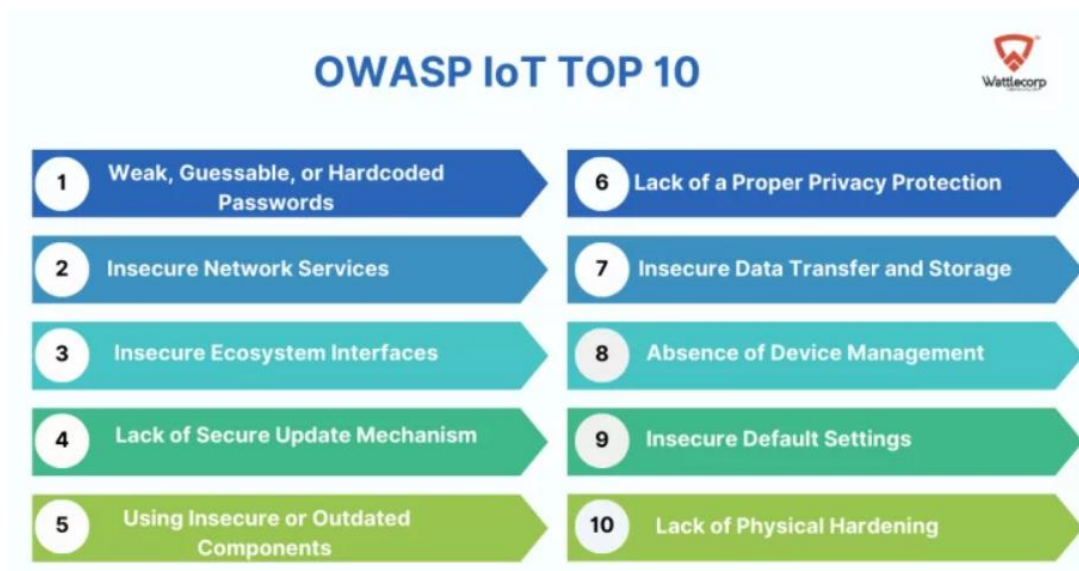
A tríade CIA (Confidencialidade, Integridade e Disponibilidade) aplica-se diretamente ao Smart Tennis Arena:

- **Confidencialidade:** Garantir que o desempenho do praticante não é interceptado por terceiros.
- **Integridade:** Assegurar que os comandos de pontuação e calibração não são forjados.
- **Disponibilidade:** Prevenir que ligações abusivas bloqueiem a ligação legítima do jogador ao alvo físico.



4. METODOLOGIA E ARQUITETURA DE HARDWARE

A metodologia adotada para este relatório consistiu numa revisão estática do código-fonte em linguagem C++ e na análise da topologia de rede local (Point-to-Point BLE). Não foram realizados testes destrutivos de intrusão, mas sim uma modelagem de ameaças baseada nas práticas do OWASP IoT Top 10.



4.1. Gestão de Energia e Disponibilidade Física

A segurança e disponibilidade de um sistema IoT dependem intrinsecamente da sua estabilidade elétrica. O projeto previa a utilização de uma fonte de 7.4V. Contudo, análises em laboratório demonstraram que esta tensão excedia as tolerâncias ideais de dissipação térmica do regulador linear da placa ESP-WROOM-32 genérica de 38 pinos, gerando ineficiência.

A intervenção metodológica consistiu na remoção de uma das células da bateria de lítio, fechando o circuito em série para obter uma tensão nominal de 3.7V. Para alimentar o microcontrolador e o módulo DFPlayer Mini adequadamente, introduziu-se um conversor *step-up*, estabilizando a saída em 5V. A célula restante possui uma capacidade nominal de 3000mAh. Considerando o consumo contínuo do rádio BLE (~100mA), a amostragem do MPU6050, e os picos de consumo do alto-falante de 4 ohms e 3W (que opera de forma intermitente, consumindo energia apenas por curtas frações de segundo durante o impacto), o sistema garante uma **autonomia projetada de 5 a 6 horas contínuas de operação gamificada**. Esta estabilidade elétrica previne vulnerabilidades de disponibilidade (reinícios inesperados por queda de tensão).

5. FRONTEIRAS DE CONFIANÇA E FLUXO D DADOS

O fluxo de dados do alvo físico é unidirecional na iteração atual: o impacto mecânico é convertido num sinal elétrico, classificado, e enviado via rádio. As fronteiras de confiança delimitam onde os dados perdem a proteção física e entram num meio partilhado.

Componente	Dados Tratados e Lógica	Fronteira de Segurança
ESP32 (<i>Firmware</i>)	Processamento vetorial ($\sqrt{x^2 + y^2 + z^2}$), cálculo de variação de força ($\Delta\text{Força}$), e <i>debounce</i> não-bloqueante de 300ms.	Memória do dispositivo e pinos GPIO. Risco de injeção lógica nulo nesta camada; foco na resiliência contra falhas de processamento.
Interface BLE (GATT)	Transmissão do estado semântico (FRACO, MÉDIO, FORTE) e medição exata do impacto em Força G.	Interface rádio. O meio aéreo de 2.4 GHz é a principal superfície de ataque, sujeita a intercepção, escuta passiva e falsificação de cliente.
Atuadores Locais	Emissão de sons pelo DFPlayer (via portas seriais RX/TX hexadecimais) e acionamento de LEDs.	Parada de emergência (falta de interrupção mecânica ou via <i>software</i> para cessar a atuação).

6. ANÁLISE DE VULNERABILIDADES

Abaixo encontra-se a dissecação técnica das vulnerabilidades presentes no código-fonte atual do projeto.

6.1. V01 - Ausência de Autenticação e *Bonding* no Emparelhamento BLE

Probabilidade: Alta | **Impacto:** Alto | **Prioridade:** CRÍTICA

- **Diagnóstico:** O código inicializa a pilha BLE através da chamada `BLEDevice::init("JoaoBobo_BLE");`, criando um servidor e instanciando o serviço e a característica de notificação (`PROPERTY_NOTIFY`). O código omite por completo a classe `BLESecurity`.
- **Vetor de Ataque:** No estado atual, o servidor inicia o *Advertising* de forma indiscriminada. Qualquer dispositivo móvel equipado com uma aplicação de exploração BLE (como o nRF Connect) pode conectar-se ao "JoaoBobo_BLE", ler o UUID da característica 6E400003... e ativar a subscrição de notificações sem qualquer desafio criptográfico (PIN) ou validação de identidade.
- **Impacto no Sistema:** Perda total de confidencialidade dos dados do treino. Adicionalmente, permite a personificação de cliente, onde um utilizador não autorizado atua como recetor dos dados, violando os princípios de privacidade e proteção de dados.

6.2. V02 - Risco de Sequestro de Ligação (*Connection Hijacking*)

Probabilidade: Média | **Impacto:** Alto | **Prioridade:** ALTA

- **Diagnóstico:** A gestão de estado de ligação é controlada pela classe `MyServerCallbacks`. Quando a função `onConnect` é acionada, a variável `deviceConnected` passa a `true`, e o ESP32 encerra a transmissão do sinal de disponibilidade (*Advertising*).
- **Vetor de Ataque:** Como a ligação (V01) não tem autenticação, um agente malicioso que chegue ao local de treino pode conectar-se preventivamente ao alvo físico. Ao fazê-lo, o ESP32 deixa de anunciar a sua presença na rede.
- **Impacto no Sistema:** Negação de Serviço (DoS) localizada. O jogador legítimo, ao tentar iniciar a sessão através da aplicação móvel oficial do Smart Tennis Arena, não encontrará o dispositivo disponível para emparelhamento, inviabilizando por completo a execução do requisito de "Execução da sessão" (RF06).

6.3. V01 - Transmissão de Telemetria de Impacto em Texto Plano

Probabilidade: Alta | **Impacto:** Médio | **Prioridade:** MÉDIA

- **Diagnóstico:** A formatação da telemetria é realizada através da concatenação de cadeias de caracteres em C++: `mensagemBLE = "IMPACTO FORTE: " + String(forcaResultante) + "G";`. Este payload é convertido via `c_str()` e enviado pela característica notificadora.
- **Vetor de Ataque:** A especificação BLE define que, sem o processo de emparelhamento seguro (Fase 2 do SMP), a cifra de ligação (AES-CCM) não é ativada. Logo, o tráfego aéreo é transmitido em *plaintext*.
- **Impacto no Sistema:** Um atacante a realizar captura passiva (*sniffing*) do tráfego aéreo obterá diretamente a leitura exata do desempenho físico do jogador (ex: 35.0G). Embora não permita alterar a pontuação na base de dados (que depende da API do *backend*), expõe dados desportivos privados.

6.4. V04 - Inexistência de Mecanismo de Parada Segura (RF22)

Probabilidade: Alta | **Impacto:** Crítico | **Prioridade:** CRÍTICA

- **Diagnóstico:** O requisito funcional RF22 do projeto exige a disponibilização de um comando de emergência e estados de falha que interrompam a execução da máquina e os *feedbacks*. O *loop* principal atual corre a ~100 Hz e avalia continuamente a variável `forcaResultante > LIMAR_FRACO`.
- **Vetor de Ataque/Risco:** Não existe nenhuma interrupção de *hardware* (*attachInterrupt*) associada a um botão físico de emergência, nem uma característica BLE RX (*Receive*) para o telemóvel forçar a suspensão. Em caso de perda de controle da máquina lançadora de bolas (Spinshot), o boneco continuará indefinidamente a processar impactos, disparar o áudio via DFPlayer no volume 30 e acender os LEDs, podendo agravar uma situação de risco físico ou stress do equipamento.
- **Impacto no Sistema:** Não conformidade grave com a especificação de segurança física e lógica.

7. CONSIDERAÇÕES FINAIS

Embora a iteração atual tenha validado a base da comunicação sem fios via BLE, o desenvolvimento ainda tem muito a melhorar, especialmente no aspecto da cibersegurança. A nossa principal dificuldade técnica no momento é o bloqueio de conexões externas indesejadas. Como o ESP32 clássico não apresenta tanta robustez e facilidade nativa para gerir políticas estritas de emparelhamento, o sistema acaba por ficar exposto a interceções de qualquer dispositivo próximo.

Os nossos próximos passos serão focados em pesquisar e implementar contornos lógicos (como modos de emparelhamento ativados por botão físico) para superar essa limitação de *hardware*. Paralelamente, priorizaremos a implementação da parada de emergência mecânica e via *software*. Acreditamos que, ao focar todos os esforços para resolver esses dois grandes desafios, o *firmware* atingirá a maturidade necessária para cumprir os requisitos de segurança exigidos para a conclusão e integração final do projeto.

8. APÊNDICE

Termo	Categoria	Definição
AES-CCM	Cibersegurança	Padrão de criptografia de ligação utilizado pelo protocolo BLE para proteger os pacotes de dados transmitidos pelo ar. Sem autenticação, não é ativado.
Advertising BLE	Comunicação Sem Fios	Modo de operação no qual o dispositivo servidor emite continuamente sinais de rádio na frequência de 2.4 GHz para anunciar sua disponibilidade de conexão a clientes próximos.
BLE (<i>Bluetooth Low Energy</i>)	Comunicação Sem Fios	Protocolo de comunicação sem fios otimizado para baixo consumo energético, encarregado de transmitir os dados de telemetria do alvo físico para os aplicativos.
Connection Hijacking	Cibersegurança	Ataque no qual um agente não autorizado se conecta a um dispositivo antes do usuário legítimo, ocultando o equipamento da rede e causando Negação de Serviço.
Conversor Step-up	Hardware	Componente eletrônico de hardware empregado para elevar e estabilizar tensões elétricas contínuas (no projeto, de 3.7V para 5V) visando a estabilidade dos atuadores.
Debounce Não-Bloqueante	Arquitetura de Software	Técnica de temporização de software (ex: filtro de 300ms) que ignora ruídos e leituras falsas ou duplicadas de um sensor físico após um impacto, sem interromper o processamento principal.
DFPlayer Mini	Hardware	Módulo atuador acionado por comandos hexadecimais via porta serial, responsável pela emissão de feedbacks de áudio durante os treinos.

Termo	Categoria	Definição
ESP32	Hardware	Microcontrolador embarcado que atua como o cérebro da arquitetura de hardware, responsável por executar o firmware, ler os sensores e gerir a conectividade de rádio.
Fronteiras de Confiança	Cibersegurança	Delimitação arquitetural que mapeia onde os dados deixam de estar protegidos internamente (memória) e passam a trafegar em um ambiente exposto e partilhado (rede sem fios).
GATT (Generic Attribute Profile)	Comunicação Sem Fios	Estrutura de organização de dados nativa do BLE que cataloga a telemetria em níveis hierárquicos de Serviços e Características (<i>Characteristics</i>).
MPU6050	Hardware	Acelerômetro microeletromecânico configurado para operar a 100 Hz, utilizado para aferir a Força G gerada pelos impactos mecânicos no alvo.
OWASP IoT Top 10	Cibersegurança	Referencial de cibersegurança reconhecido mundialmente que lista e modela as vulnerabilidades mais críticas enfrentadas por sistemas da Internet das Coisas.
Processamento Vetorial e Impulso	Arquitetura de Software	Abordagem algorítmica matemática (baseada na raiz quadrada dos eixos espaciais) usada para calcular a força resultante e diferenciar impactos contundentes de meros balanços do equipamento.
Programação Assíncrona	Arquitetura de Software	Paradigma de código implementado por meio de contadores de milissegundos (millis()), substituindo os bloqueios rígidos de tempo (delay()) e permitindo a leitura contínua de sensores em paralelo com outras tarefas.

Termo	Categoria	Definição
SMP (Security Manager Protocol)	Cibersegurança	Camada de segurança obrigatória da especificação Bluetooth responsável por gerir os processos criptográficos de emparelhamento (<i>Pairing</i>) e vínculo (<i>Bonding</i>).
Sniffing	Cibersegurança	Ataque passivo de escuta de rede que consiste em capturar pacotes de dados transmitidos em texto plano (sem criptografia) pelo ar.
Tríade CIA	Cibersegurança	Modelo fundamental de proteção da informação baseado nos pilares de Confidencialidade (privacidade dos dados), Integridade (precisão das pontuações e comandos) e Disponibilidade (funcionamento ininterrupto).
UUID	Comunicação Sem Fios	Identificador exclusivo em formato alfanumérico usado para endereçar os serviços e características do BLE de forma única na rede.

9. REFERÊNCIAS

[O que é Bluetooth Low Energy \(BLE\) e quais as vantagens desse tipo de conexão?](#)

• [Tecnoblog](#)

[Part G Generic Attribute Profile \(GATT\)](#)

[O que é Tríade CIA e como aplicá-la na cibersegurança?](#)

[SMP - ESP32 - — ESP-IDF Programming Guide v6.1 documentation](#)

[AES - Padrão de criptografia avançado: o que é e como funciona - CryptoID](#)

[OWASP IoT Top 10: 10 Vulnerabilities and Fixes](#)

GOOGLE. *Gemini*. Modelo de linguagem baseado em inteligência artificial. Mountain View: Google, 2026. Disponível em: <https://gemini.google.com>. Acesso em: 23 set. 2026.